

# Security Recommendations for Jackson Corporation

## Firewall Architecture and Traffic Segmentation

- Implement a multi-layer firewall architecture (Defense in Depth).
- Separate network zones into External Zone, DMZ, and Internal Network.
- Apply strict access control rules and network segmentation (VLANs) to limit lateral movement.

## Web Server Placement and Protection

- Move public-facing web servers to a DMZ.
- Restrict direct access to internal systems.
- Use Reverse Proxy to filter traffic.
- Implement Web Application Firewall (WAF) to protect against SQL Injection and XSS attacks.

## Network Monitoring and Visibility

- Deploy a SIEM system for centralized logging.
- Collect logs from firewalls, servers, and endpoints.
- Enable real-time alerting and anomaly detection.

## Breach Detection and Incident Awareness

- Implement IDS/IPS for intrusion detection and prevention.
- Use behavior-based detection systems.
- Establish a SOC and incident response plan.

## Secure Remote Work Access

- Require VPN for all remote users.
- Enforce Multi-Factor Authentication (MFA).
- Apply least privilege access control.
- Monitor and log remote sessions.

## Secure Software Development Practices

- Adopt Secure SDLC.
- Perform code reviews and static analysis (SAST).
- Conduct penetration testing.
- Train developers in secure coding practices.

## Web Application Security (OWASP Top 10)

- Enforce strong password policies and account lockout mechanisms.

- Use HTTPS (TLS encryption).
- Implement input validation and output encoding.
- Use parameterized queries to prevent SQL Injection.
- Sanitize inputs to prevent XSS.
- Keep software and dependencies updated.